

Departamento de Engenharia Informática

**SWitCH Cyber - Pós-Graduação em Segurança de Informação,
Cibersegurança e Privacidade**

**Arquitetura, Desenho e Desenvolvimento de Software Seguro (ADDSS)
Professor Paulo Baltarejo Sousa**

Ano letivo 2025/2026

M1: Survey on Vulnerabilities

Grupo 3

Vulnerabilities Overview



CVE-2025-21298

Operating System

Windows Privilege Escalation - Improper validation of memory objects in privileged system structures allows escalation to SYSTEM.

9.8 Critical



CVE-2023-21716

Microsoft Word RCE

Heap-based buffer overflow in RTF font table parsing in wwlib.dll allows remote code execution via malicious RTF files.

9.8 Critical



CVE-2022-29864

Free Category (OPC UA)

Denial of Service via uncontrolled resource consumption in the OPC UA .NET Standard Stack session handling.

7.5 High



CVE-2025-21298

Windows OS — Local Privilege Escalation

Severity

9.8 Critical

Attack Vector

Local

Impact

CIA Triad

CVE-2025-21298 - Overview

- **Vulnerability Name:**

Windows OLE Remote Code Execution Vulnerability

- **CVE ID:**

CVE-2025-21298

- **Severity:**

Critical (CVSS Score: 9.8)

- **Target:**

Microsoft Windows ole32.dll (Object Linking and Embedding)

- **Impact:**

- Allows an attacker to execute arbitrary code remotely without user interaction (Zero-Click) via Outlook or Word



CVE-2025-21298 - Technical Details



Root Cause Analysis

- Vulnerability Type: Double-Free Memory Corruption
- Affected Component: ole32.dll
- Technical Trigger: malformed OlePress streams within RTF files handling
- Flaw: Failure to nullify a pointer after failed read operation leading to a second release of the same memory address



Exploitation Impact

- Zero-Click RCE: Allows Remote Code Execution by opening a crafted RTF file in Word.
- Memory Instability: Triggers immediate application failure
- System Compromise: Enables an attacker to execute arbitrary code with the same privileges as the logged-in user.

Exploitation Chain/Scenario

1 Initial Access

Delivery of a specially crafted .rtf containing malicious OLE object

2 Process Attachment

Monitoring WINWORD.EXE via WinDbg to capture memory management

3 Trigger

Open RTF file to trigger the vulnerable parsing logic in ole32.dll

4 Execution

Double-Free condition causes process instability (multiple First Chance Exceptions)

CVE-2025-21298 - Mitigation & Lessons



Patch & Mitigation

Security Update

Microsoft corrected the flawed validation logic within the affected component.

Apply Patch Immediately

Install the official security update on all affected Windows systems.

Least Privilege

Enforce the principle of least privilege and restrict administrative accounts.

Monitor Kernel Activity

Use EDR tools to detect abnormal kernel-level operations.



Key Lessons

Input Validation

Strict validation in privileged code is essential to prevent exploitation.

Defense in Depth

Multiple defensive layers mitigate exploitation impact even when one fails.

Patch Management

Effective and timely patching reduces attack surface significantly.

Kernel Security

Kernel-level components require rigorous security design and auditing.



CVE-2023-21716

Microsoft Word - Remote Code Execution (RTF)

CVSS v3.1

9.8 Critical

Attack Vector

**Network /
Remote**

Auth Required

None

Affected: Microsoft Office 2010, 2013, 2016, 2019 & Microsoft 365 Apps | Patched: Feb 14, 2023

CVE-2023-21716 - Overview

- **Vulnerability Name:**
Microsoft Word Remote Code Execution Vulnerability
- **CVE ID:**
CVE-2023-21716
- **Severity:**
Critical (CVSS Score: 9.8)
- **Primary Target:**
Microsoft Word (2010, 2013, 2016 and 2019) and Microsoft 365 Apps
- **Attack Vector:**
Rich Text Format (RTF) files
- **Impact:**
 - Allows an attacker to execute arbitrary code remotely without user interaction (Zero-Click) via Word, application instability and Denial of Service (DoS)



CVE-2023-21716 – Technical Details



Root Cause Analysis

- **Vulnerability Type:** Heap Based Buffer Overflow (CWE-122)
- **Affected Component:** wwlib.dll (Microsoft Word Library)
- **Trigger:** Malformed \fonttbl structures within RTF files
- **Technical Flaw:**
 - Failure to validate the number of entries supplied by the user
 - Processing thousands of repetitive font definitions exceeds allocated memory boundaries
 - Unmanaged memory operation overwrites adjacent data, leading to heap instability



Exploitation Impact

- **Zero-Click RCE:** Allows Remote Code Execution by opening or previewing a crafted RTF file in Word.
- **Memory Instability:** Triggers immediate application failure
- **System Compromise:** Enables an attacker to execute arbitrary code with the same privileges as the logged-in user.
- **CIA :** Directly affects Confidentiality (data theft), Integrity (file modification) and Availability (system crashes).

Attack Flow

1 Weapon

Attacker generates the malformed RTF file with oversized font table (\fonttbl)

2 Delivery

RTF file delivered via email or download link to users with unpatched versions

3 Trigger

Victim opens/views the file and wwlib.dll starts parsing the table without boundary checks

4 Execution & Impact

Excessive entries cause Heap based Buffer Overflow → Denial of Service & Remote Code Execution

CVE-2023-21716 - Lab Simulation



Lab Environment

VM: Windows 10 + Microsoft Office 2013 (Host-Only)

Tool: Python script to generate malicious RTF with massive \fonttbl entries

Analysis: rtfdump for RTF structure verification

Monitoring: Process Monitor tracking WINWORD.EXE and wwlib.dll activity



Observed Results

- 1. Application Crash:** Word entered loading state with intensive processing and terminated unexpectedly
- 2. Activity:** Process Monitor confirmed wwlib.dll loaded
- 3. Overflow Evidence:** Memory-related entries indicated Buffer Overflow results
- 4. Technical Proof:** The WINWORD.EXE process exited with status 255 (forcibly terminated), confirming a critical failure due to heap-based memory exhaustion (CWE-122)

CVE-2023-21716 - Mitigation & Lessons



Patch & Mitigation

Official Security Update

Microsoft released in Feb 2023 an update to fix the improper memory validation in RTF parsing component.

File Block Policy

Configure GPO to prevent Word from opening RTF files from untrusted/unknown sources.

Protected View

Enable for all documents from untrusted sources to execute them in a restricted sandbox.

Least Privilege

Enforce least privilege principles for user accounts.



Key Lessons

Input Validation

Applications parsing complex structures must enforce strict boundary checks to prevent memory exhaustion.

Memory Safety

Unmanaged memory operations without validation lead to heap instability and control flow manipulation.

Timely Patching

Public disclosure + PoC demonstrations significantly increase the risk for unpatched systems.

System Hardening

The combination of Sandboxing (Protected View) and Least Privilege is critical to contain the impact of an RCE.



CVE-2022-29864

OPC UA .NET Standard Stack - Denial of Service

CVSS v3.1

7.5 High

Attack Vector

**Network /
Remote**

Auth Required

None

Affected: OPC UA .NET Standard Stack v1.04.368 | Disclosed: June 16, 2022

CVE-2022-29864 - Technical Details



Root Cause

The OPC UA stack fails to impose limits on the number of concurrent sessions or total memory allocated across sessions. Each session requires dedicated resources (memory buffers, security contexts, message queues) that grow unbounded.



Attack Mechanism

An attacker floods the server with concurrent session requests (OpenSecureChannel → CreateSession → ActivateSession), each consuming heap memory until RAM is exhausted and the server crashes.

Attack Flow

1

Session Flood

Attacker opens hundreds of concurrent sessions

2

Resource Drain

Server allocates memory for each session without limits

3

RAM Exhaustion

Heap memory grows unbounded until out-of-memory

4

Server Crash

OPC UA server crashes, clients lose connectivity

CVE-2022-29864 - Lab Infrastructure



VM1 — OPC UA Server

Windows Server
.NET Core Reference Server v1.4.370.12



VM2 — Client 1

Windows 11
UaExpert 2.0.1



Validation Process

1. Clients establish normal sessions with server
2. VM4 launches session flooding script
3. Server memory grows until out-of-memory crash
4. Legitimate clients lose connection — DoS confirmed



VM3 — Client 2

Windows 11
UaExpert 2.0.1



VM4 — Attacker

Python exploit script
Session flooding

CVE-2022-29864 - Mitigation & Lessons



Patch & Mitigation

Patch

Update to OPC UA .NET Standard Stack v1.4.368.58+.
Introduces session limits and memory caps.

Network Segmentation

Isolate OPC UA servers from untrusted networks.

Access Control

Restrict OPC UA to authorized clients via firewall rules and ACLs.

Monitoring

Deploy IDS for abnormal session creation and monitor memory usage.



Key Lessons

Resource Limits Are Critical

Servers must enforce strict bounds on memory allocation per session and globally.

Stack-Level Bugs Propagate

A single flaw in a shared stack impacts a wide ecosystem of industrial products.

Defense in Depth

Segmentation and monitoring compensate when patches aren't yet applied.

Coordinated Disclosure

Research efforts like Clarity Team82 are vital for industrial protocol security.